

# Official disclaimer

This is a vulnerability report citing concerns about contentkeeper express. What it isn't is a "how to get unfiltered internet access (100% working)" tutorial. I, adison Verlice, am not responsible if you decide it's a great idea to bypass your schools filtering software. Do **not** try any of this. Depending on your school, it may constitute a violation of your schools acceptable use policy. In order to minimize the impact, as you will see in the document via persistence (see vulnerability 2) I have redacted certain information, for example, the contact URL in which you can use for turning off the filtering software. This vulnerability report will also not show you how to powerwash your school issued device, nor will it suggest it's a good idea to do so. The reason this fact is in the report is to allow other security researchers and IT personnel to take steps to reproduce the vulnerability.

Also, i, the writer and researcher of the vulnerability, was authorized to do security research and have reported it to the proper channels, and have given both the company and district time to act before publishing the report. If anyone working at ativion wants to contact me for further details, please see the information about the author heading below to get my contact information

Note: no information about the school district I tested on is provided in order to protect the district in question. This is a security research paper, not a get an IT guy fired paper.

## Non technical summary (non IT, school administrators such as principals and superintendents)

This is a set of policy bypass exploits that bypass the ContentKeeper filtering systems.

The risks to this vulnerability include:

- Violation of the [Children's Internet Protection Act \(CIPA\)](#) CIPA requires always on filtering and monitoring for school-managed devices, and this set of exploits, when used, will undoubtedly violate CIPA as a result.
- harm to students: if a student successfully uses the exploits within the technical analysis, the student is exposed to harmful material (pornography, violence, drugs, etc) online.
- Logging: you will lose logs of the student logged into the chromebook even if it is a school managed device.

It is recommended you bring this to your IT administrators and/or Ativion (the vendor of ContentKeeper) and have them read the technical analysis below.

Vulnerability report.

## Vendor information

Name: Atvion, inc.

Website: <https://ativion.com>

Covered product: ContentKeeper

Product website: <https://www.ativion.com/contentkeeper/>

Description: ContentKeeper, originally made by ContentKeeper technologies, is a web and internet filtering platform. It is installed by several schools across the globe to protect student internet.

In this vulnerability report, we will talk specifically about ContentKeeper express.

ContentKeeper Express (CK Express/CKETP) is ContentKeepers solution to cloud based web filtering, reducing the need for schools to open ports and set up proxies in their networks.

This works by installing an extension and an android based application on chromebooks in order to carry out filtering.

## Contact information for author:

Name: Adison Verlice

email : [averlicetech@proton.me](mailto:averlicetech@proton.me)

PGP encryption public key (for secure contact to this email): <https://blindsoft.net/publickey.asc>

Note: you can use the following tools to verify this key

- [openPGP keys verification at keys.openpgp.org](https://keys.openpgp.org)
- [MIT keyserver](https://mitkeyserver.org)

Phone number: N/A.

Other emails:

[adison.verlice@blindsoft.net](mailto:adison.verlice@blindsoft.net).

## A note about specifics of vulnerabilities

There is a vulnerability that has its contact domain redacted in order to prevent this exploit from being used in the wild. Furthermore, it requires a complete reset of the chromeOS device with ContentKeeper being in previsioning mode, where it must connect for the first time. As either a preconfigured (issued by your school already, not turned on and/r previsioned) or powerwashed/reset device.

# Vulnerabilities

## 1. Wifi off (manual)

This involves turning the wifi off on the chromebook when the CK-ETP loading screen is displayed. This works by keeping the wifi off for 5 minutes, then turning it back on again.

Note: sometimes this will not work, but most of the time, it does.

## 2. DNS

On first initialization, Contentkeeper express is required to heartbeat to a very specific domain which will not be said within this document for security reasons.

It will pull policies, and ping this domain to ensure it can initialize correctly, as well as update policies that may not be updated, E.G> if a schools IT administrator decides they want to add a new domain to the blocklist, it will push to all devices from this domain.

On first initialization, this can be exploited. Using any commercial dns provider like.opendns, we can block this domain in order to ensure the extension cannot call it to download policies for the first time.

# Result of both

Both will, after 5 minutes, result in unfiltered internet access. The student will be given unfiltered internet, and if the automated vulnerability (vulnerability 2) is deployed, unlogged, internet access.

# Solutions for schools:

## 1. Use network level filtering

Rather than relying on an agent to do the filtering, use a proxy server in your network or on a commercial cloud provider (amazon web services, google cloud platform) to force a central point of contact to the device at all times without initialization. This will push the proxy to all chromeOS devices in your fleet, even if the device is reset, as long as it is a managed device.

## 2. Have CK-ETP always try to provision on campus

If possible, try to have ck express provision itself on campus. This will ensure even if the device is fully reset, as long as the CK-Express TP extension is activated and working, it will always provision and go back to normal because these vulnerabilities only work on CKs very first initialization process.

## 3. (For Ativion) use a fail safe policy

Rather than having the device immediately fail after 5 minutes of attempted heartbeat, have a fail safe policy in place in order to block internet traffic while the device is not connected to the contentkeeper organization. This is done so that even while the device cannot connect to contentkeeper, it will not have any unfiltered access to the internet.